Website Vulnerability Assessment & Penetration Test Report

Target: http://redacted-site.example

redacted-site.example_VAPT_Report
Generated 2026-11-09 06:28:09Z

Generated by Automated Website VAPT Framework v1.0.0 by Shrayan Biswas · LinkedIn

1. Executive summary

9 findings recorded for http://redacted-site.example: 0 Critical, 1 High, 3 Medium, 1 Low, 4 Informational. Automated checks are indicators and must be validated; items marked CANDIDATE need manual confirmation.

2. Scope

Scope: http://redacted-site.example. Testing consisted of non-destructive automated checks plus any manual findings recorded in this register.

3. Methodology

OWASP WSTG-aligned phases: reconnaissance, attack-surface mapping, configuration, authentication, authorization, input validation, session, API, client-side, validation, CVSS 3.1 scoring.

4. Environment and tools

Python 3 (urllib, ssl, socket), Flask; optional: Nmap, WhatWeb, Nikto, SSLScan; manual: Burp Suite, OWASP ZAP, SQLmap

5. Scans performed

Scan	Started (UTC)	Status	Requests	Modules
No scans recorded.				

6. Vulnerability summary

ID	Title	Severity	CVSS	Status
f2bc68e2	Sensitive resource reachable: /.git/HEAD	**High**	7.5	Open
809c72e8	Application served over plain HTTP	**Medium**	4.8	Open
d8bc3bef	Missing Content-Security-Policy header	**Medium**	4.2	Open
035c0953	Missing clickjacking protection	**Medium**	4.2	Open
fcccefa7	Missing X-Content-Type-Options header	Low	3.1	Open
9f027e15	robots.txt reveals paths	*Informational*	0.0	Open
d24ac554	Missing Referrer-Policy header	*Informational*	0.0	Open
4aa586f6	Missing Permissions-Policy header	*Informational*	0.0	Open
38b4f307	Server/technology version disclosure	*Informational*	0.0	Open

7. Detailed findings

---

f2bc68e2 - Sensitive resource reachable: /.git/HEAD

Severity: **High** (CVSS 7.5, `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`)
Affected component: `/.git/HEAD` **Phase:** Phase 2/3 **Status:** Open

Description: A path commonly associated with secrets, backups or debug data returned content.

Impact / business impact: Potential disclosure of credentials, source or configuration.

Proof of concept / evidence:

```
GET /.git/HEAD -> 200 (21 bytes)
```

Recommendation: Remove the resource from the web root or restrict it with authentication.

Retest notes: Not yet retested

809c72e8 - Application served over plain HTTP

Severity: Medium (CVSS 4.8, `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N`)
Affected component: `http://redacted-site.example` **Phase:** Phase 3 **Status:** Open

Description: The target does not use TLS.

Impact / business impact: Traffic can be intercepted or modified in transit.

Proof of concept / evidence:

```
See evidence/ folder
```

Recommendation: Serve the site over HTTPS and redirect HTTP to HTTPS.

Retest notes: Not yet retested

---

d8bc3bef - Missing Content-Security-Policy header

Severity: Medium (CVSS 4.2, `CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N`)
Affected component: `/` **Phase:** Phase 3 **Status:** Open

Description: No CSP is sent, which reduces defence-in-depth against XSS and data injection.

Impact / business impact: Weakens browser-side protections.

Proof of concept / evidence:

```
Header 'content-security-policy' absent from response.
```

Recommendation: Add: Content-Security-Policy: default-src 'self'; frame-ancestors 'self' (tune for the app)

Retest notes: Not yet retested

035c0953 - Missing clickjacking protection

Severity: Medium (CVSS 4.2, `CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N`)
Affected component: `/` **Phase:** Phase 9 **Status:** Open

Description: Neither X-Frame-Options nor CSP frame-ancestors is present.

Impact / business impact: Page may be framed by a malicious site (clickjacking).

Proof of concept / evidence:

```
See evidence/ folder
```

Recommendation: Add X-Frame-Options: DENY (or SAMEORIGIN) or CSP frame-ancestors.

Retest notes: Not yet retested

---

fcccefa7 - Missing X-Content-Type-Options header

Severity: Low (CVSS 3.1, `CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N`)
Affected component: `/` **Phase:** Phase 3 **Status:** Open

Description: Browsers may MIME-sniff responses.

Impact / business impact: Weakens browser-side protections.

Proof of concept / evidence:

```
Header 'x-content-type-options' absent from response.
```

Recommendation: Add: X-Content-Type-Options: nosniff

Retest notes: Not yet retested

9f027e15 - robots.txt reveals paths

Severity: *Informational* (CVSS 0.0, `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:N`)
Affected component: `/robots.txt` **Phase:** Phase 1 **Status:** Open

Description: robots.txt lists paths that may hint at sensitive areas.

Impact / business impact: Information disclosure that helps attackers focus.

Proof of concept / evidence:

```
Disallow: /admin/
Allow: /
Sitemap: /sitemap.xml
```

Recommendation: Do not rely on robots.txt for secrecy; protect sensitive paths with access control.

Retest notes: Not yet retested

---

d24ac554 - Missing Referrer-Policy header

Severity: *Informational* (CVSS 0.0, `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:N`)
Affected component: `/` **Phase:** Phase 3 **Status:** Open

Description: Full URLs may leak to third parties via the Referer header.

Impact / business impact: Weakens browser-side protections.

Proof of concept / evidence:

```
Header 'referrer-policy' absent from response.
```

Recommendation: Add: Referrer-Policy: strict-origin-when-cross-origin

Retest notes: Not yet retested

4aa586f6 - Missing Permissions-Policy header

Severity: *Informational* (CVSS 0.0, `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:N`)
Affected component: `/` **Phase:** Phase 3 **Status:** Open

Description: Browser features are not explicitly restricted.

Impact / business impact: Weakens browser-side protections.

Proof of concept / evidence:

```
Header 'permissions-policy' absent from response.
```

Recommendation: Add: Permissions-Policy: geolocation=(), camera=(), microphone=()

Retest notes: Not yet retested

38b4f307 - Server/technology version disclosure

Severity: *Informational* (CVSS 0.0, `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:N`)
Affected component: `response headers` **Phase:** Phase 3 **Status:** Open

Description: Headers reveal software and version information.

Impact / business impact: Helps attackers match known CVEs.

Proof of concept / evidence:

```
server: nginx/1.18.0 (Ubuntu)
```

Recommendation: Remove or genericise Server / X-Powered-By headers.

Retest notes: Not yet retested

8. Retesting results

- No retests recorded yet.

9. Conclusion

Prioritise Critical/High items, then re-run the scan and update statuses to Retest Passed.

Automated Website VAPT Framework v1.0.0 © 2026 Shrayan Biswas · MIT License · https://www.linkedin.com/in/shrayan-biswas-a1259225a/